INDIVIDUAL REFLECTION (D4)

Name:	WONG Lai Man (Max)	**Student ID:**	24810493
Course:	03CIT4067 Cybersecurity Project	**Role:**	Team Leader (Group 7)
Project Title:	Topic 15: Design and Implementation of a Web Application Security Risk Detection and Remediation Demonstration System Based on OWASP Top 10		

1. PROBLEM SOLVED

As the Team Leader for Group 7 (Topic 15), my primary objective was to design and implement a hybrid web application security demonstration system. The core technical problem we solved was bridging the gap between automated vulnerability detection (using OWASP ZAP) and actual code-level remediation. Specifically, we addressed the newly emphasized OWASP Top 10: 2025 category, A10 (Mishandling of Exceptional Conditions). We successfully developed a custom Python Flask module that enforces a strict "fail-closed" architecture, ensuring that unexpected errors (like database timeouts) default to denying access (HTTP 503) rather than inadvertently granting it. Additionally, we mitigated A05 (Security Misconfiguration) by implementing robust HTTP security headers and disabling debug modes in production.

2. ADVANTAGES

The main advantage of our proposed solution is its practical, educational value. Unlike traditional Dynamic Application Security Testing (DAST) tools that only flag risks, our hybrid architecture (combining OWASP Juice Shop with custom Flask modules) provides a visual, side-by-side comparison of vulnerable and remediated code. From a project management perspective, adopting the Agile/Scrum methodology allowed us to maintain a strict bi-weekly sprint cycle. When we faced a critical blocker—team member Zoutao's hospitalization and network restrictions in Mainland China—I utilized agile risk mitigation by reallocating tasks. Zoutao shifted to Red Team documentation (Appendix C), while Mustafa handled local Docker deployments. This flexibility ensured we met all internal deadlines without compromising the project's academic rigor.However, our current system has limitations. It primarily relies on manual code reviews and baseline ZAP scans, lacking an automated CI/CD security pipeline. Additionally, while we deeply covered A05 and A10, our code-level remediation demonstrations for other categories (like A01 or A03) are currently limited to theoretical analysis rather than full backend implementations.

3. NEXT STEPS

If this project were to continue into a third phase, I would focus on automating the remediation verification process. Currently, we rely on manual code reviews and baseline ZAP scans. The next step would be to integrate a CI/CD pipeline (e.g., using GitHub Actions) that automatically runs OWASP ZAP scans and unit tests for the "fail-closed" logic every time a new commit is pushed to the repository. Furthermore, I would expand the custom Flask module to cover more OWASP 2025 categories, such as A01 (Broken Access Control), by implementing Role-Based Access Control (RBAC) demonstrations.

4. OVERALL THOUGHTS

Leading Group 7 through the 03CIT4067 Cybersecurity Project has been an immensely rewarding experience. It significantly enhanced my technical proficiency in Python, Flask, and Docker, while deepening my understanding of modern web vulnerabilities. More importantly, it honed my project management and crisis resolution skills. Navigating the "Zero-Error" submission policy and managing team dynamics under pressure taught me the true value of clear communication, strict internal deadlines, and agile adaptability. I am proud of our team's ability to deliver a comprehensive, APA 7th-compliant technical report and a functional proof-of-concept, and I feel fully prepared to apply these skills in my future career as a cybersecurity professional.